

恶意代码分析与防治技术实验报告

R77



网络空间安全学院

信息安全专业

2211985 李佳璐

一、实验目的

运行 R77 程序，实现对指定的进程、文件、注册表、网络连接的隐藏

二、实验原理

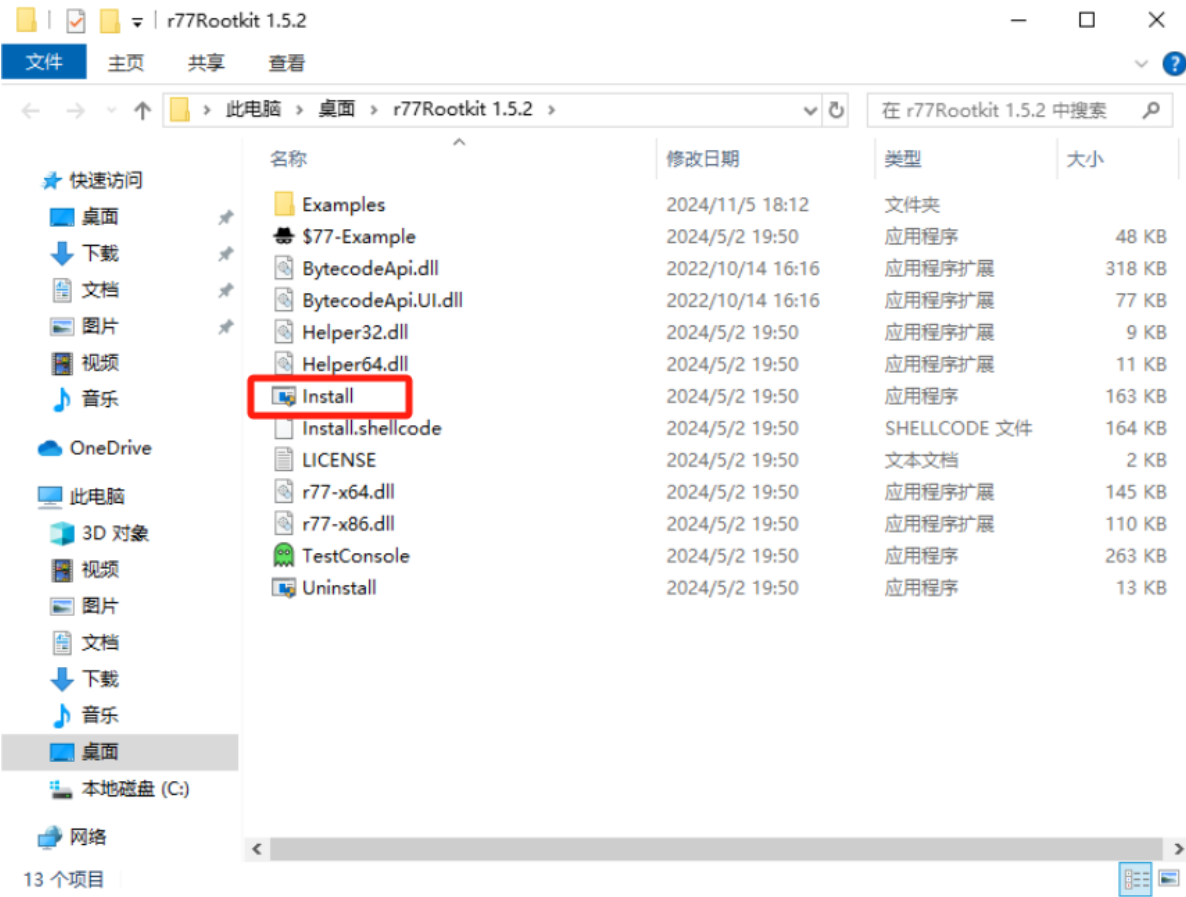
在网址[r77 Rootkit - bytecode77](#)下载R77 RootKit安装包。

R77 Rootkit 是一种用于隐藏和持久化的恶意软件，它主要通过修改操作系统核心组件或执行路径来达到潜伏和控制系统的目的。Rootkit 作为一种恶意软件类型，通常用于隐藏其存在，使得普通用户和安全软件很难检测到它的活动。

其本质目标是通过修改操作系统内核或用户态组件，实现对受害系统的隐蔽控制和持久化存在。它通常通过劫持系统调用、注入恶意驱动程序、隐藏自身行为等手段来实现高效的潜伏。

三、实验过程

解压后可以看到：



运行 `Install.exe` 将r77注入到每个正在运行的进程中，并使rootkit在系统上持久存在。新进程在运行其自己的指令之前会被注入。这是通过挂钩进程创建实现的。安装后，r77将设置在重新启动后启动，并在用户登录之前注入所有进程。

• 进程

隐藏前：

Processes
Config System
Control Pipe

Process	PID	Platform	Integrity	User	Flags	Inject	Detach	Hide by PID
\$77-Example.exe	248	64	Medium	lijialu		Inject		Hide
ApplicationFrameHost.exe	5788	64	Medium	lijialu		Inject		Hide
audiodg.exe	4256	64						Hide
ChsIME.exe	4116	64	High	lijialu				Hide
ChsIME.exe	4856							Hide
csrss.exe	636							Hide
csrss.exe	720							Hide
ctfmon.exe	4028	64	High	lijialu				Hide
dasHost.exe	1128							Hide
dllhost.exe								Hide
dllhost.exe								Hide
dllhost.exe								Hide
dllhost.exe								Hide
dwm.exe								Hide
explorer.exe								Hide
FileCoAuth.exe								Hide
fontdrvhost.exe								Hide
fontdrvhost.exe								Hide
lsass.exe								Hide
Memory Compression								Hide
MicrosoftEdgeUpdate.exe	4984							Hide
MsDefenderSecurityCenter.exe	3816							Hide

r77 Rootkit Example File

\$77-Example.exe (PID: 248)

This executable's filename starts with "\$77"

- A task manager that is injected with r77 will not display this process.
- File Explorer (or any other file browser) will not display this file.
- etc... (see documentation)

CPU Usage: 0%
?
Close

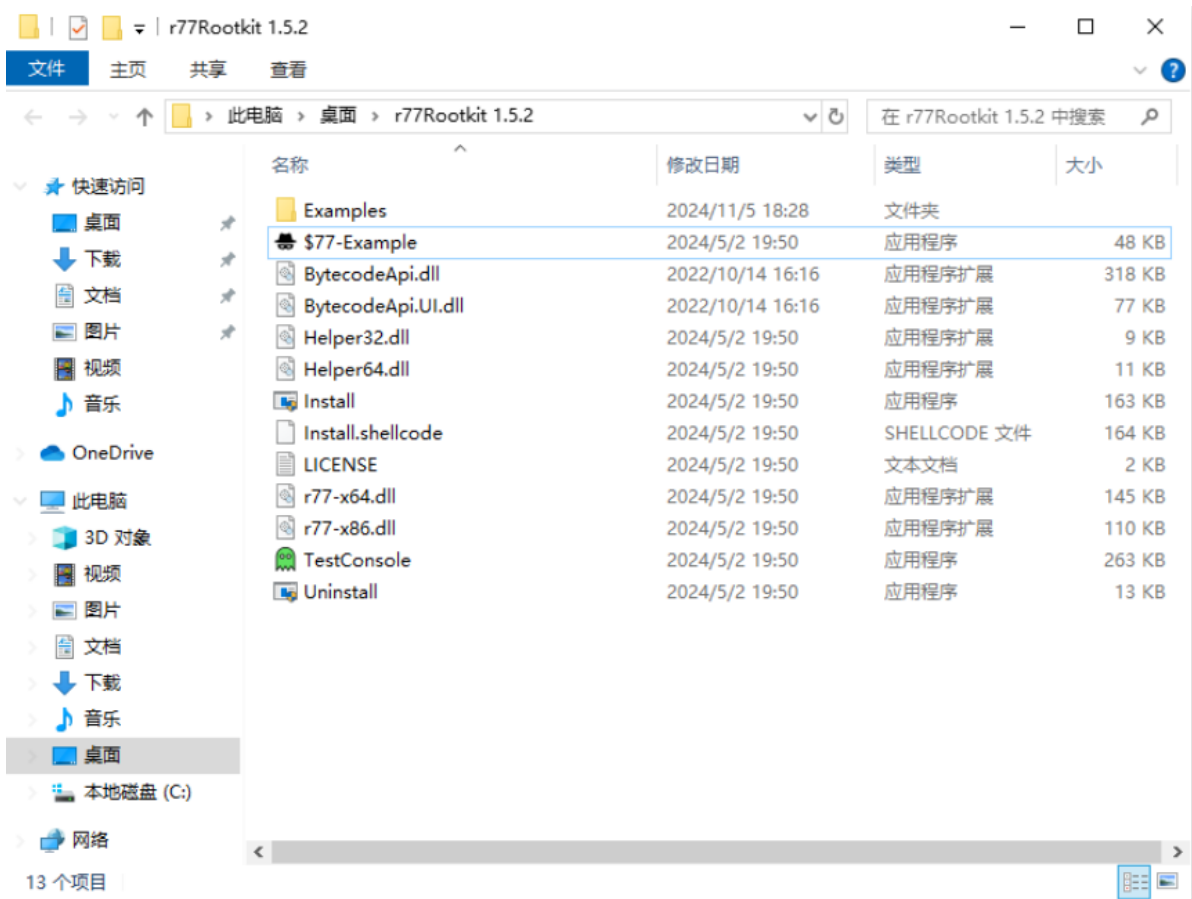
隐藏后：

Processes
Config System
Control Pipe

Process	PID	Platform	Integrity	User	Flags	Inject	Detach	Hide by PID
ApplicationFrameHost.exe	5788	64	Medium	lijialu		Injected	Detach	Hide
audiodg.exe	9312	64						Hide
ChsIME.exe	4116	64	High	lijialu				Hide
ChsIME.exe	4856							Hide
csrss.exe	636							Hide
csrss.exe	720							Hide
ctfmon.exe	4028	64	High	lijialu				Hide
dasHost.exe	1128							Hide
dllhost.exe	944							Hide
dllhost.exe	2312							Unhide
dllhost.exe	3116							Hide
dllhost.exe	5568	64	Medium	lijialu		Injected	Detach	Hide
dllhost.exe	7196	64	Medium	lijialu		Inject		Hide
dllhost.exe	8220	64	High	lijialu				Hide
dwm.exe	816							Hide
explorer.exe	4356	64	Medium	lijialu		Injected	Detach	Hide
FileCoAuth.exe	8016	64	Medium	lijialu		Injected	Detach	Hide
fontdrvhost.exe	948							Hide
fontdrvhost.exe	956							Hide
lsass.exe	852							Hide
Memory Compression	1660							Hide
MicrosoftEdgeUpdate.exe	4984							Hide

文件

隐藏前：



\$77test	2024/11/5 18:59	文件夹
BinaryCollection	2024/9/22 18:57	文件夹
example1	2024/9/22 18:57	文件夹
r77Rootkit 1.5.2	2024/11/5 19:02	文件夹
TCPView	2024/11/5 18:46	文件夹
tools	2024/9/23 10:37	文件夹
\$77test1	2024/11/5 18:59	RTF 文档
\$77test2	2024/11/5 18:59	文本文档
Lab03-02.dll	2024/9/9 22:14	应用程序扩展
r77Rootkit 1.5.2	2024/11/4 10:52	压缩(zipped)文件...
strings	2024/9/9 10:40	应用程序
TCPView	2024/11/5 18:45	压缩(zipped)文件...
新建文本文档	2024/9/22 18:57	文本文档

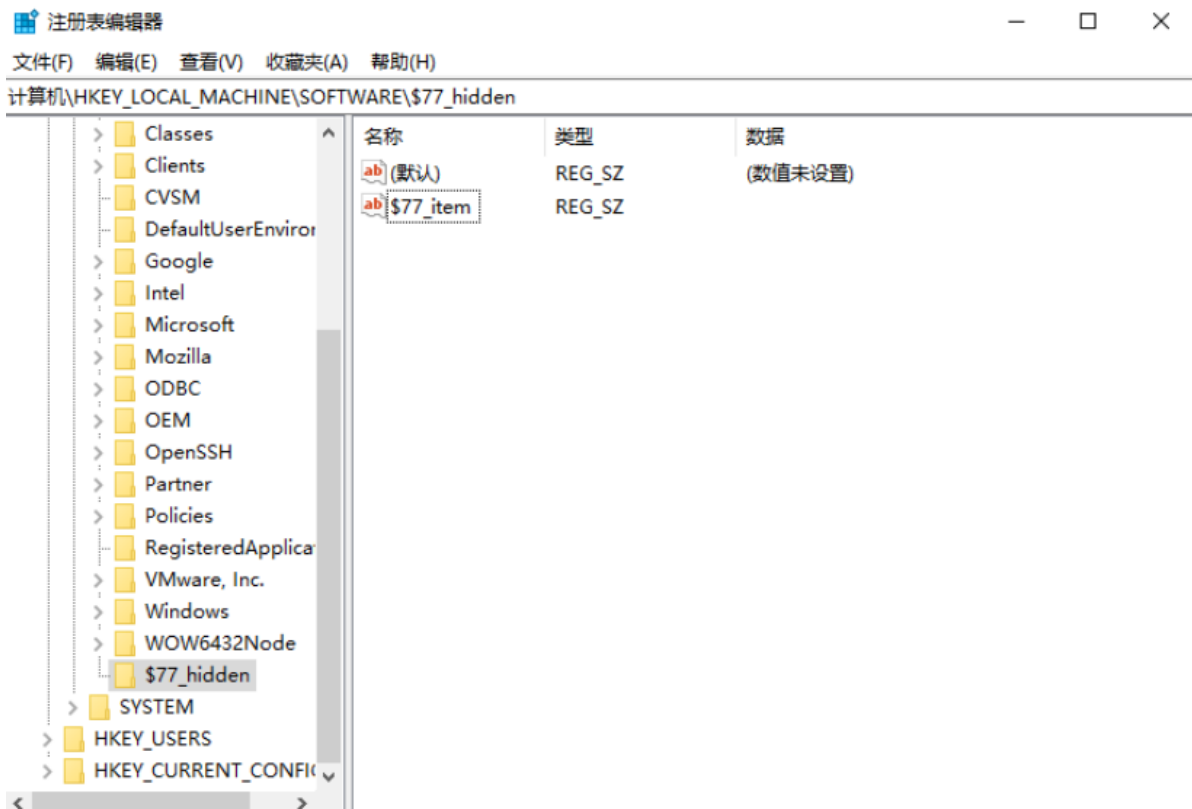
隐藏后：

 Examples	2024/11/5 19:02	文件夹	
 BytecodeApi.dll	2022/10/14 16:16	应用程序扩展	
 BytecodeApi.UI.dll	2022/10/14 16:16	应用程序扩展	
 Helper32.dll	2024/5/2 19:50	应用程序扩展	
 Helper64.dll	2024/5/2 19:50	应用程序扩展	
 Install	2024/5/2 19:50	应用程序	
 Install.shellcode	2024/5/2 19:50	SHELLCODE 文件	
 LICENSE	2024/5/2 19:50	文本文档	
 r77-x64.dll	2024/5/2 19:50	应用程序扩展	
 r77-x86.dll	2024/5/2 19:50	应用程序扩展	
 TestConsole	2024/5/2 19:50	应用程序	
 Uninstall	2024/5/2 19:50	应用程序	

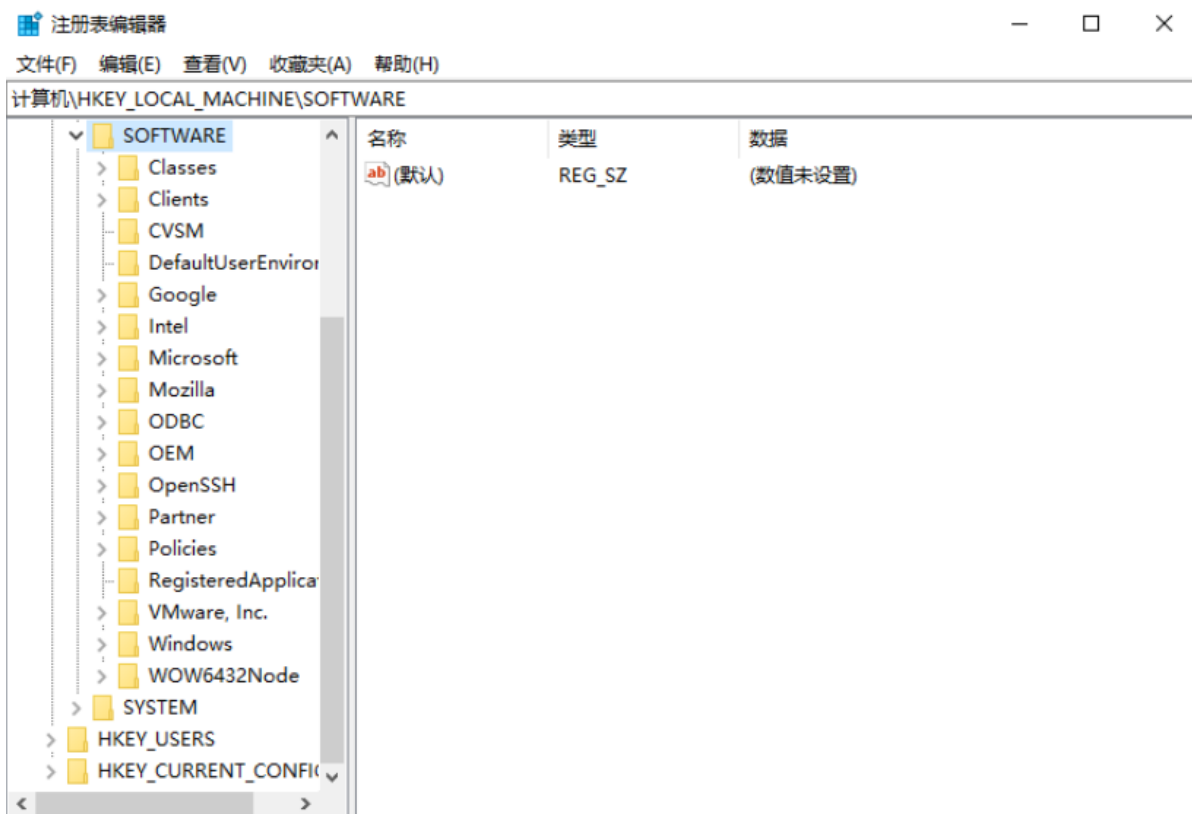
名称	修改日期	类型	大
 BinaryCollection	2024/9/22 18:57	文件夹	
 example1	2024/9/22 18:57	文件夹	
 r77Rootkit 1.5.2	2024/11/5 19:02	文件夹	
 TCPView	2024/11/5 18:46	文件夹	
 tools	2024/9/23 10:37	文件夹	
 Lab03-02.dll	2024/9/9 22:14	应用程序扩展	
 r77Rootkit 1.5.2	2024/11/4 10:52	压缩(zipped)文件...	
 strings	2024/9/9 10:40	应用程序	
 TCPView	2024/11/5 18:45	压缩(zipped)文件...	
 新建文本文档	2024/9/22 18:57	文本文档	

注册表

隐藏前：



隐藏后：



网络连接

[Technical Documentation.pdf](#)

按照指导文件上所给出的有关配置系统中网络连接隐藏部分：

2.7.5 Local TCP Ports

The subkey `$77config\tcp_local` contains DWORD values with local TCP ports to be hidden.

2.7.6 Remote TCP Ports

The subkey `$77config\tcp_remote` contains DWORD values with remote TCP ports to be hidden.

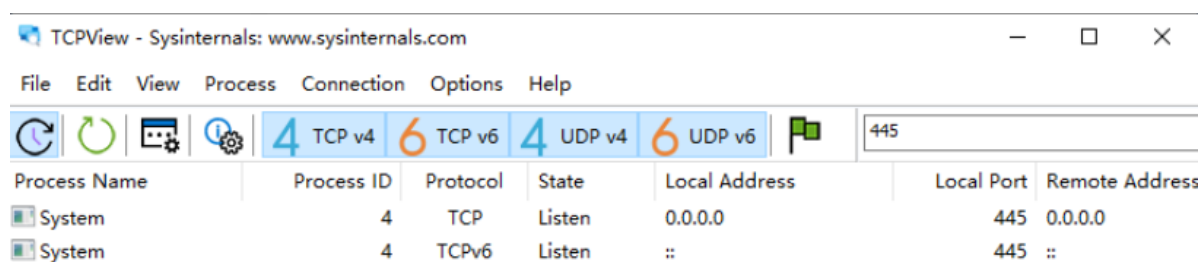
2.7.7 UDP Ports

The subkey `$77config\udp` contains DWORD values with UDP ports to be hidden.

针对端口号进行隐藏

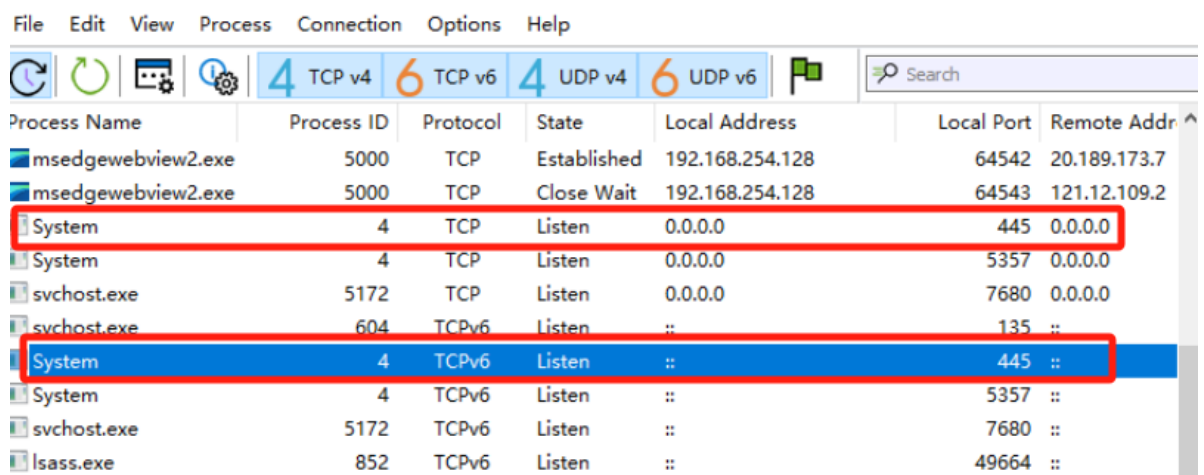
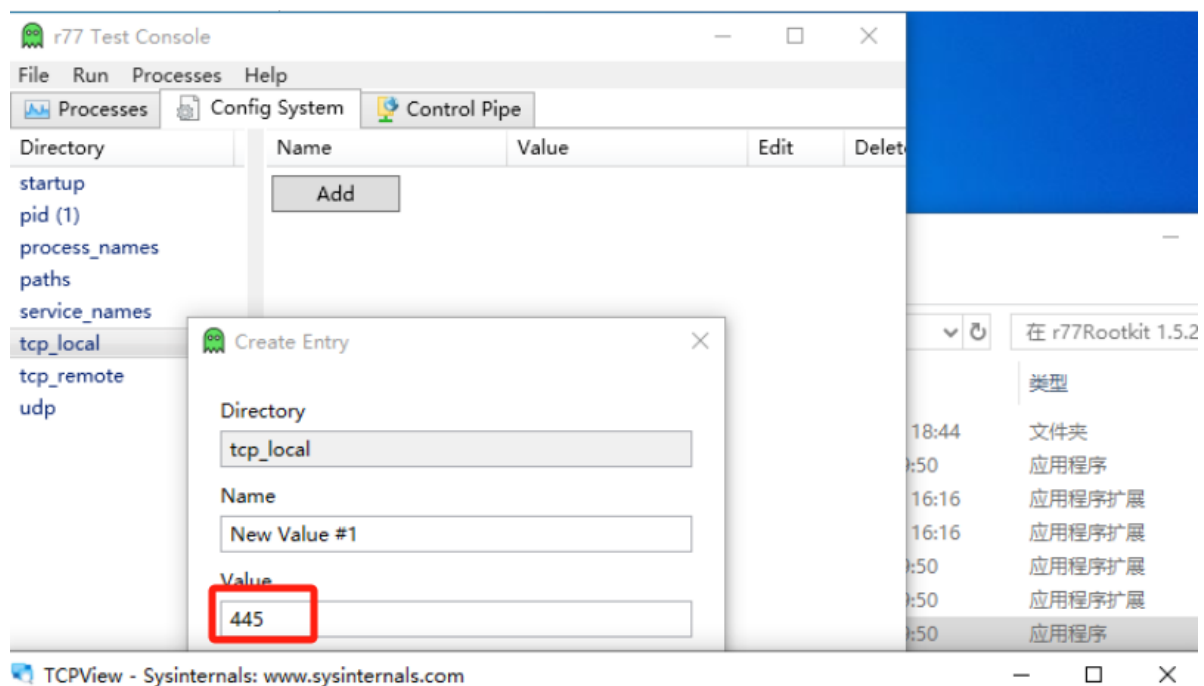
以端口号为445的一个tcp网络连接为例：

隐藏前：（通过搜索可以查看到有两个445端口的tcp网络连接）

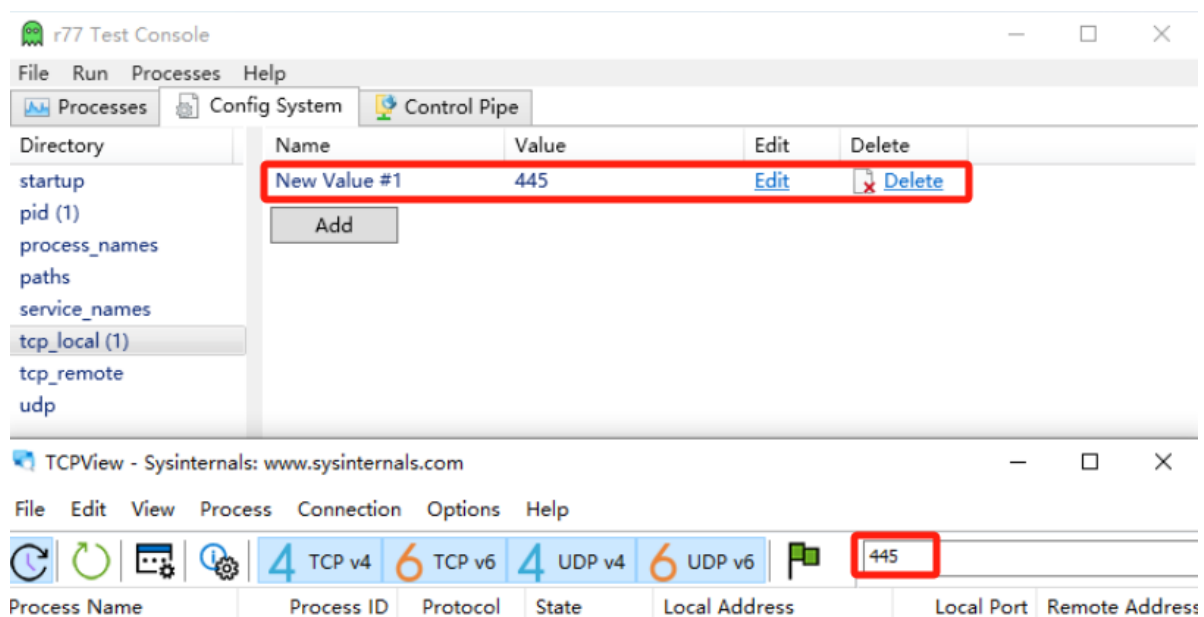


Process Name	Process ID	Protocol	State	Local Address	Local Port	Remote Address
System	4	TCP	Listen	0.0.0.0	445	0.0.0.0
System	4	TCPv6	Listen	::	445	::

添加tcp_local监控端口值为445



隐藏后：



可见已经成功隐藏。

六、实验结论及心得体会

[Technical Documentation.pdf](#)

(1) 概述 R77 所利用的 Windows 的 Detours 机制

R77 所利用的 Windows 的 **Detours 机制** 是一种通过修改程序的执行流程来实现注入和劫持功能的技术。Detours 机制本质上是一种代码注入方法，通过修改 Windows API 调用的执行路径，将恶意代码插入到正常的程序流中。这种技术常用于监视、修改、或干扰其他程序的行为，恶意软件可能利用这种技术来实现各种目的，比如窃取信息、禁用安全检测机制或对系统进行持久化控制。

Detours 机制的工作原理

1. API Hooking (API 钩子) :

- Detours 机制通过 **API hooking** 技术来实现对函数调用的劫持。恶意软件或调试工具会在应用程序调用某个 API 函数时，将该函数的地址替换为恶意代码的地址。
- 例如，Detours 可能会在一个常见的 Windows API 调用（如 `CreateFile`、`ReadFile` 等）之前插入自定义代码，用来监视文件操作或修改操作的行为。

2. 代码注入与修改:

- 恶意软件可能通过修改目标程序的内存或修改进程的执行流程来实现钩子。这通常包括使用 `VirtualAlloc` 或其他系统调用来分配内存空间并将恶意代码注入到程序中。
- 恶意软件还会利用 Windows 提供的 `DetourTransactionBegin`、`DetourUpdateThread`、`DetourAttach` 和 `DetourTransactionCommit` 等 API 函数来注册钩子函数，并修改被劫持函数的地址。

3. 透明性和隐蔽性:

- Detours 技术能够在不引起显著性能下降的情况下进行有效的函数劫持，因此恶意软件利用这种方式会尽可能隐蔽，以避免被杀毒软件检测到。
- 通过这种技术，恶意代码可以在系统级别插入并修改程序的行为，甚至可能绕过一些安全检测工具。

4. 应用场景:

- **恶意软件控制**: 通过 Detours，恶意软件能够劫持操作系统的 API，监控或修改用户行为，窃取敏感信息（如键盘输入、网络请求、文件访问等）。
- **反调试**: 恶意软件可能使用 Detours 机制来钩住调试相关的 API，避免被调试器发现或分析。
- **绕过安全防护**: Detours 可以用来绕过安全软件的监控，避免被杀毒软件或行为分析工具检测。

使用 Detours 的典型操作流程:

1. **初始化**: 恶意软件首先通过系统调用分配内存并将恶意代码写入内存中。
2. **劫持目标函数**: 通过 Detours API 或直接操作内存，恶意代码将目标 API 函数的指针更改为指向自己的函数。
3. **执行恶意行为**: 当原始程序调用 API 时，会先跳转到恶意代码，恶意代码可以执行任何操作，例如记录用户输入、窃取文件、修改系统设置等。
4. **恢复控制**: 在执行完恶意操作后，恶意代码会恢复到原始的 API 函数，允许目标程序继续正常运行。

(2) 完成本次实验后，对R77实现各类隐藏的方法进行总结

1. 前缀隐藏

指导文档中给出，R77定义了一个"\$77"隐藏前缀

2.6 Hide Prefix

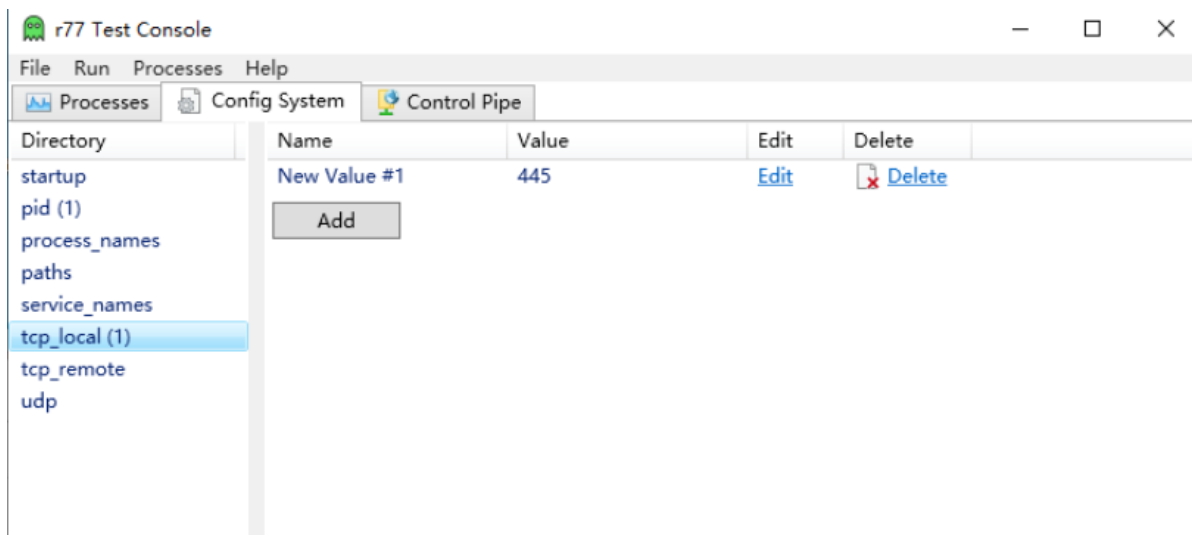
```
#define HIDE_PREFIX L"$77"
```

The hide prefix is a compile time variable. It specifies the beginning of a name that is hidden. This applies to the filenames of processes, to files and directories, and all other entities described in section 2.5. If the documentation mentions the string \$77, it refers to the compile time variable that is used throughout the code. This is the single place to change the prefix. Additionally, this change must be applied in `GlobalAssemblyInfo.cs`.

Processes that are hidden by prefix cannot be injected with r77. The `DllMain` of r77 will return `FALSE`, if the process starts with the prefix.

隐藏前缀是一个编译时的变量。它指定了一个被隐藏的名称的开头。这适用于**进程的文件名、文件和目录**，以及**文件、注册表和网络连接**的所有其他实体。如果以字符串\$77开头，即会被隐藏。

2. 使用配置系统添加要监控隐藏的进程或文件等



1. 进程隐藏

r77 通过挂钩（hooking）系统 API 实现对进程的隐藏。它拦截 Windows API 函数（例如 `NtQuerySystemInformation`），修改返回的进程列表，将特定的进程从列表中移除。这样，使用系统任务管理器或者其他进程监视工具时，看不到被隐藏的进程。

2. 文件隐藏

r77 也会挂钩文件系统的相关 API（例如 `NtQueryDirectoryFile`），从文件列表中移除特定的文件或文件夹。它可以识别特定文件名或路径，然后修改返回的结果，以实现对指定文件或文件夹的隐藏。

3. 注册表隐藏

对于注册表项的隐藏，r77 通过挂钩注册表相关的 API（例如 `NtEnumerateKey` 和 `NtQueryKey`），过滤掉特定的注册表键或值，使其在注册表编辑器等工具中不可见。这同样是通过拦截 API 返回的数据并过滤出指定内容来实现的。

4. 网络连接隐藏

r77 使用类似的技术来隐藏网络连接。通过挂钩网络相关的 API 或操作系统接口（例如 `NtDeviceIoControlFile`）实现对特定端口、协议或 IP 地址的隐藏。它可能拦截系统的网络连接查询请求，从结果中删除特定的连接信息。